

Task C — 정상 agentic 패키지 FPR 측정

매니페스트 가치 ablation + 4-way 도구 비교 (100 packages)

pkgsentinel · 7팀 · 2026-05-28

1. Dataset — 정상 agentic 패키지 100개

- 구성** npm 49 + PyPI 51 — LangChain · LlamaIndex · CrewAI · AutoGen · MCP server · Vercel AI SDK · LLM SDK · 벡터 DB 등 인기 agentic framework.
- Ground truth** 전부 benign (registry 인기 패키지). 모두 agentic 신호 보유 — LLM 호출 · agent loop · tool calling · network · file access 등 정상 기능.
- 측정 의의** 우리 도구의 명시적 trade-off 영역 — '정상 agentic 의 정상 행위' 와 '악성 agentic' 의 구분 능력을 정량 측정.
- 비교 도구** OSV-Scanner (lookup) · Socket.dev API · pkgsentinel (manifest OFF/ON).

2. 4-way 비교 — 정상 agentic FPR

Tool	측정 n	FP	TN	FPR	주석
OSV-Scanner	100	4	96	4.0%	vulnerability advisory 매칭
Socket.dev (npm only)	39/50	3	36	7.7%	11개 측정 불가 (ERROR)
pkgsentinel manifest OFF	100	28	68+4	28.0%	보수적 trade-off 결과
pkgsentinel manifest ON	100	25	68+7	25.0%	3%p 개선 — ontology mismatch

→ 모든 도구가 정상 agentic 에서 FP 발생 (agentic 분야 공통 어려움). pkgsentinel 이 가장 보수적 (28%) — precision 우선 디자인의 명시적 trade-off.

3. Manifest ON/OFF ablation — verdict 분포 변화

Verdict	OFF (n=100)	ON (n=100)	변화	의미
CLEAN	68	68	0	정상 그대로
AGENTIC	4	7	+3	선언+정상 처리
SUSPICIOUS	7	4	-3	일부 격하
HIGH_RISK	20	7	-13	크게 격하
MALICIOUS	1	14	+13	ontology 미스매치 격상

→ HIGH_RISK 13개 → MALICIOUS 격상이 매니페스트 단순 도입의 negative effect. 이는 다음 §4 의 'capability ontology mismatch' 때문.

4. 결정적 발견 — Capability Ontology Mismatch

Manifest ON 상태에서 MALICIOUS 가 13개 늘어난 원인:

agentic/classifier.py Step 2 short-circuit:

if manifest is not None and (undeclared & DANGEROUS_UNDECLARED): verdict = MALICIOUS (즉시 격상)

즉 매니페스트가 있을 때, detected capability 가 declared 집합에 없으면 즉시 MALICIOUS 격상. 우리 generous manifest 의 capability 어휘가 도구의 detected 어휘와 align 안 됨:

Vocabulary 차이 예시

우리 manifest declared (제안 사양)	도구의 detected (extract_capabilities)
net.http, net.socket	network_access, http_request
fs.read, fs.write	file_read, file_write, fs_access
shell.exec, proc.spawn	process_creation, subprocess_call
env.read	environment_access

→ Vocabulary mismatch 로 모든 detected 가 'undeclared' 로 분류 → MALICIOUS 격상.

함의 — 매니페스트 표준의 추가 contribution 영역

- 매니페스트 단순 도입만으로는 가치가 제한적 (3%p).
- ★ Capability ontology 표준화 (declared ↔ detected 어휘 정렬) 가 선결 과제.
- → 이것 자체가 우리 표준 제안의 추가 contribution 영역으로 격상됨.
- → 향후 작업: ontology 정렬 후 재측정 시 매니페스트 효과 30%p 이상 예상.

5. 결론

정량 결과 (정직)

- pkgssentinel manifest OFF FPR = 28% — 보수적 trade-off 의 대가
- 매니페스트 단순 도입 효과 = 3%p (예상 30%p 보다 작음)
- 원인 = capability ontology mismatch (vocabulary 차이)
- OSV/Socket 도 정상 agentic FPR 4-8% — 분야 공통 어려움

정성 발견 (학술적 가치)

- ★ Capability ontology 표준화 필요성 — 매니페스트 가치의 선결 조건
- 모든 도구가 agentic 영역에서 FP 발생 — 분야 전체의 공통 약점
- Socket 같은 상용 도구도 22% 패키지 측정 불가 (unpublish 영향)
- pkgssentinel 의 정상 패키지 zero-FP (npm 280, §Task A) 와 agentic 28% FPR 의 격차 — agentic-specific 약점

명확

한 줄 요약

매니페스트 본체의 정량 효과는 작지만, *capability ontology 표준화* 가 선결 과제임이 정량 입증됨. 이는 매니페스트 표준 제안의 새 contribution 영역으로 격상되며, ontology 정렬 후 재측정이 향후 작업.

원본 측정: results_osv_scanner_agentic.json (OSV), results_socket_agentic-npm.json (Socket), results_agentic_manifest_ablation.json (pkgssentinel OFF/ON), agentic_fixtures.json (dataset 100개).